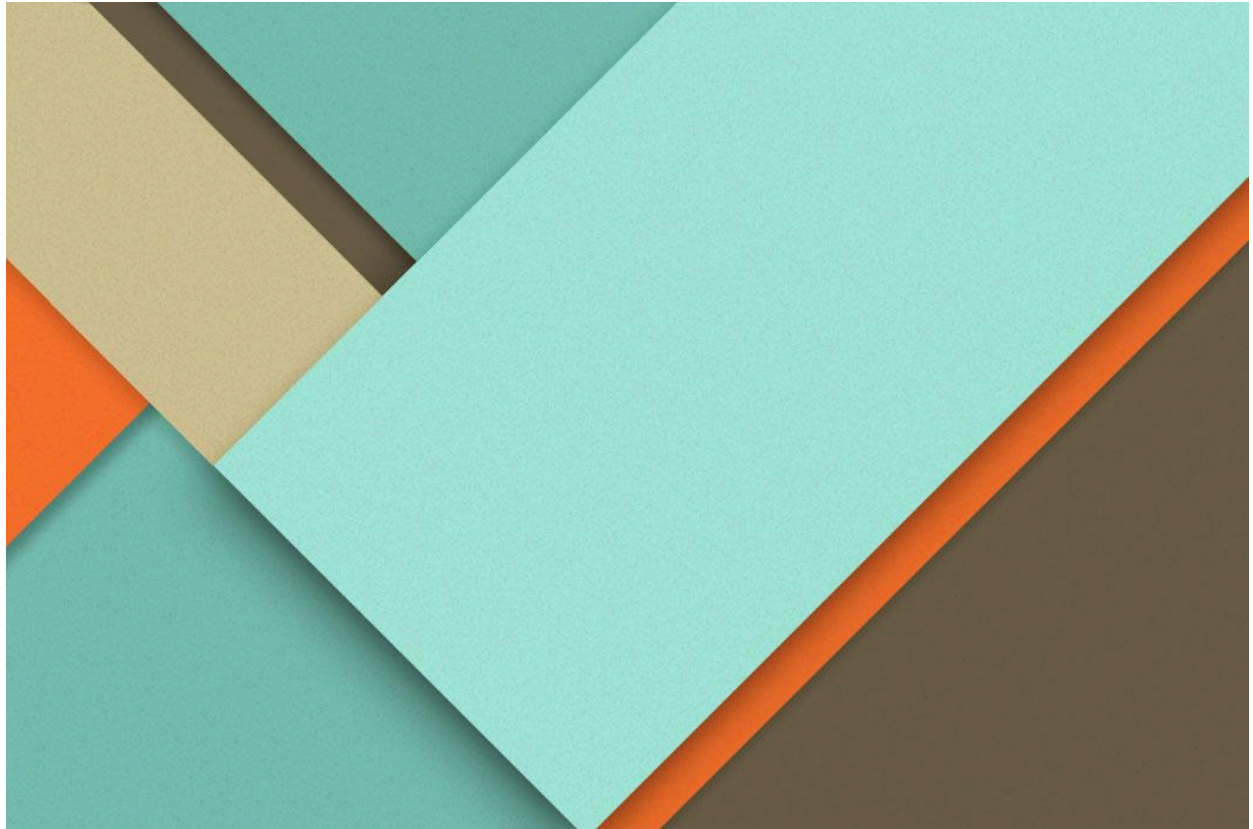




Proyecto de sensores glucémicos - Modelado de sistema y amenazas

2026-05-28

Juan Vera

Resumen

Este documento incluye un diseño de un sistema de gestión de los datos de un sensor que recoge los niveles de azúcar en sangre. El sensor lo llevan puesto los pacientes en sus casas y envía cada 10 minutos los datos a una aplicación en sus terminales móviles personales. Estos datos se envían una vez al día al hospital del paciente donde se incorporan a su historial clínico. En el hospital, tanto el personal de enfermería como el personal de medicina tiene acceso al historial clínico de los pacientes que tienen asignados.

En la revisión presente se incluye un análisis de los siguientes requisitos

- Como paciente, quiero que sea crítico conservar la confidencialidad de los datos de los pacientes y que solo el personal asignado al paciente (médico o de enfermería) pueda acceder a ellos
- Como personal médico, en caso de que los niveles de azúcar en sangre que detecta el sensor superen cierto umbral, quiero que se envíe inmediatamente una alerta a un centro de emergencias. Además, quiero que este umbral sólo puede ser establecido por el personal médico, no por el de enfermería
- Como director del hospital, quiero que haya un registro de todas las personas que accedan a un historial clínico.
- Como director del hospital, quiero que el sistema ofrezca la capacidad de hacer investigaciones científicas sobre los historiales clínicos anonimizados.

Aviso

Este es un ejercicio para una sesión de demostración de modelado de amenazas y se ha generado con inteligencia artificial (Gemini), adaptando el resultado. Los prompts se muestran a continuación y han seguido las fases comunes del modelado de amenazas

¿En qué estamos trabajando?

Eres un ingeniero de seguridad. Te han encargado el diseño de un sistema de gestión de los datos de un sensor que recoge los niveles de azúcar en sangre. El sensor lo llevan puesto los pacientes en sus casas y envía cada 10 minutos los datos a una aplicación en sus terminales móviles personales. Estos datos se envían una vez al día al hospital del paciente donde se incorporan a su historial clínico. En el hospital, tanto el personal de enfermería como el personal de medicina tiene acceso al historial clínico de los pacientes que tienen asignados. Ten en cuenta los siguientes requisitos que han llegado de los diferentes usuarios:

- Como paciente, quiero que sea crítico conservar la confidencialidad de los datos de los pacientes y que solo el personal asignado al paciente (médico o de enfermería) pueda

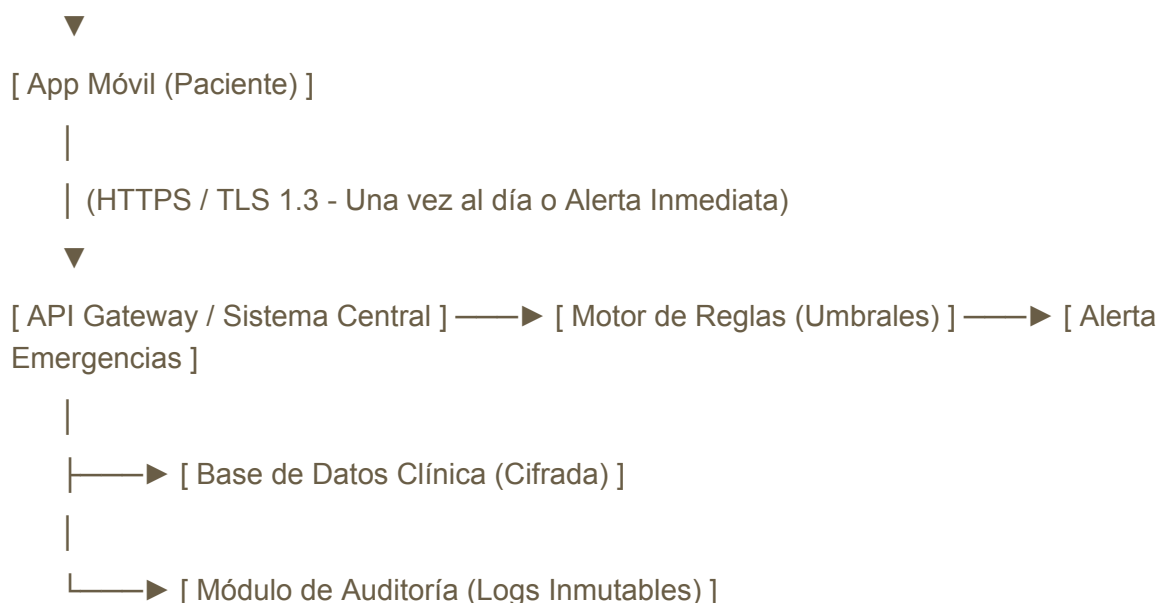
acceder a ellos - Como personal médico, en caso de que los niveles de azúcar en sangre que detecta el sensor superen cierto umbral, quiero que se envíe inmediatamente una alerta a un centro de emergencias. Además, quiero que este umbral solo puede ser establecido por el personal médico, no por el de enfermería - Como director del hospital, quiero que haya un registro de todas las personas que accedan a un historial clínico. Describe los componentes del sistema, identificando los componentes principales y cómo se comunican entre ellos.
Prioriza los componentes del sistema en cuanto a su criticidad
¿Qué puede salir mal? Análisis STRIDE
Haz un análisis de amenazas STRIDE para los sistemas identificados en la tabla anterior. Para cada una de los tipos STRIDE identifica al menos tres amenazas diferentes. Presenta los resultados en forma de tabla.
¿Qué podemos hacer para arreglarlo? Priorización
Prioriza las amenazas de la tabla anterior atendiendo a la criticidad del sistema al que afectan
Prioriza las amenazas según la probabilidad estimada de explotación
Prioriza las amenazas STRIDE identificadas en el sistema que has diseñado basándose en su criticidad y su probabilidad de explotación. Presenta los resultados en forma de tabla.
Nueva iteración del modelado: nueva funcionalidad
La dirección del hospital ha pedido una nueva funcionalidad: capacidad de hacer investigaciones científicas sobre los historiales clínicos anonimizados. Identifica una amenaza para cada una de los tipos STRIDE, prioriza las amenazas atendiendo a su criticidad y explotabilidad y presenta los resultados en forma de tabla

Arquitectura y Componentes del Sistema

Para cumplir con todos los requisitos, dividiremos el sistema en tres capas: **Dispositivo (Edge)**, **Backend en la Nube/Hospital (Core)** y **Consumidores (Frontend)**.

[Sensor IoT]

| (Bluetooth LE / Cifrado)



A. Capa del Paciente (Edge)

- **Sensor IoT (Glucómetro Continuo):** Recoge los niveles de azúcar cada 10 minutos. No tiene gran capacidad de cómputo, por lo que almacena los datos temporalmente de forma cifrada.
- **Aplicación Móvil Personal:** Actúa como *gateway* local. Recibe los datos del sensor, los almacena localmente en un contenedor seguro (como el *Keychain* o *Keystore* del teléfono) y se encarga de la transmisión.

B. Capa de Control y Lógica (Backend del Hospital)

- **API Gateway y Servicio de Ingesta:** El punto de entrada único para las aplicaciones móviles y los terminales del hospital. Se encarga de la autenticación, autorización y mitigación de ataques (como DDoS).
- **Servicio de Identidad y Acceso (IAM):** El motor que gestiona los roles. Aquí implementaremos un **Control de Acceso Basado en Atributos y Roles (ABAC/RBAC)** para asegurar que un médico o enfermero *solo* vea a los pacientes que tiene explícitamente asignados.
- **Motor de Reglas y Alertas:** Analiza los datos en tiempo real. Si un dato llega y supera el umbral crítico, este componente dispara la alerta sin esperar al volcado diario de datos.

C. Capa de Almacenamiento y Auditoría

- **Base de Datos Clínica (Historial Clínico):** Almacena los datos estructurados. Debe estar cifrada en reposo (*Encryption at Rest*).

- **Módulo de Auditoría y Logs (SIEM):** Un sistema independiente y protegido donde se registra cada lectura, modificación o acceso a los historiales clínicos.

2. Flujo de Comunicación y Mitigación de Riesgos

La comunicación entre estos componentes está diseñada específicamente para cumplir con las peticiones de los usuarios:

Flujo 1: Del Sensor a la App Móvil (Cada 10 minutos)

- **Cómo se comunican:** A través de **Bluetooth Low Energy (BLE)**.
- **Seguridad:** Se implementa un emparejamiento seguro (*Secure Connections*) con cifrado AES-CMAC para evitar ataques de intermediario (*Man-in-the-Middle*).

Flujo 2: De la App Móvil al Hospital (Diario / Inmediato por Alerta)

- **Cómo se comunican:** Conexión **HTTPS utilizando TLS 1.3** con *Certificate Pinning* en la app para garantizar que solo hable con el servidor legítimo del hospital.
- **Cumplimiento de Alerta Médica:** Aunque el volcado general de datos es una vez al día, la App Móvil evalúa localmente cada lectura de 10 minutos. Si detecta un valor anómalo (o si el backend procesa la trama y detecta que supera el umbral), se salta la restricción de "una vez al día" y envía un payload de **Alerta Inmediata** al API Gateway, que a su vez contacta al Centro de Emergencias mediante una API prioritaria y cifrada.

Flujo 3: Acceso del Personal Médico y de Enfermería

- **Cómo se comunican:** A través de la red interna del hospital o VPN médica segura hacia el Sistema Central.
- **Cumplimiento de Confidencialidad y Roles:** * Cuando un enfermero o médico intenta abrir un historial, el componente IAM valida la **relación de asignación** (¿Es este paciente parte de su cupo/disponibilidad?). Si la respuesta es no, el acceso se deniega automáticamente.
 - **Control de Umbrales:** El sistema expone el endpoint **POST /config/thresholds** protegido exclusivamente para usuarios con el rol **Médico**. Si un usuario con rol **Enfermería** intenta modificarlo, el API Gateway rechaza la petición con un error **403 Forbidden**.

Flujo 4: Registro de Actividad (Petición del Director)

- **Cómo se comunican:** De manera asíncrona mediante un bus de eventos (como Kafka) para no ralentizar el sistema.
- **Cumplimiento de Auditoría:** Cada vez que el API Gateway procesa una solicitud de "Lectura de Historial", envía un evento al **Módulo de Auditoría**. Este log guarda: *ID del usuario, Rol, ID del paciente, Fecha/Hora y Acción realizada*.

- *Nota de seguridad:* Estos logs se envían a un almacenamiento de tipo **WORM** (*Write Once, Read Many*), asegurando que nadie (ni siquiera un administrador del sistema o un atacante que haya escalado privilegios) pueda borrar el rastro de quién consultó un historial.

Análisis de la criticidad de los sistemas

Clasificaremos los componentes en tres niveles de criticidad: **Crítico (Tier 1)**, **Alto (Tier 2)** y **Operacional (Tier 3)**.

1. Nivel Crítico (Tier 1): Impacto Vital Inmediato

Si cualquiera de estos componentes falla o es vulnerado, **la vida del paciente corre peligro inminente** o se rompe la regla de oro de la confidencialidad médica desde el primer segundo.

- **Motor de Reglas y Alertas de Emergencia:** Es el componente más crítico. Si este módulo se cae o sufre un retraso (*delay*), un paciente con una hipoglucemia o hiperglucemia severa no recibirá asistencia médica a tiempo. Su disponibilidad debe ser del 99.999% (cinco nueves).
- **Servicio de Identidad y Acceso (IAM):** Controla las autorizaciones (ABAC/RBAC). Si este componente falla de forma "abierta", cualquiera podría ver los datos de cualquier paciente (violación masiva de privacidad). Si falla de forma "cerrada", los médicos no podrán ver los datos para tratar una emergencia.
- **Sensor IoT y App Móvil (Módulo de Detección de Umbrales):** La capacidad de la app para procesar el dato cada 10 minutos y decidir saltarse el envío diario para lanzar una alerta inmediata es vital. Si la app se congela o el sensor transmite datos corruptos (fallo de integridad), el sistema central queda ciego.

2. Nivel Alto (Tier 2): Impacto Legal y Continuidad del Tratamiento

Un fallo aquí no matará a un paciente en los próximos 10 minutos, pero generará **sanciones legales multimillonarias (como RGPD)**, pérdida de confianza total o incapacidad de realizar el seguimiento médico diario.

- **Módulo de Auditoría y Logs Inmutables (WORM):** Es la garantía exigida por la dirección. Si un atacante o un empleado malintencionado puede acceder a los historiales y borrar los logs de acceso, el hospital pierde la capacidad de demostrar el cumplimiento legal y forense. Debe ser altamente íntegro y protegido contra modificaciones.
- **Base de Datos Clínica (Cifrada):** Almacena el histórico. Su criticidad es alta en cuanto a confidencialidad (cifrado) e integridad. Si se corrompe, el personal médico pierde el

histórico de la evolución del paciente, afectando a las decisiones de tratamiento a largo plazo.

- **API Gateway (Endpoint de Configuración de Umbrales):** Este punto específico debe estar ultra protegido. Si un atacante logra saltarse el control y modificar los umbrales de los pacientes, podría provocar que nunca se disparen las alarmas de emergencia o, por el contrario, colapsar el centro de emergencias con falsos positivos.

3. Nivel Operacional (Tier 3): Eficiencia y Rutina

Componentes necesarios para el funcionamiento del día a día, pero cuyo fallo temporal (horas) es tolerable y gestionable mediante procedimientos de contingencia tradicionales.

- **Servicio de Ingesta Diaria (Volcado de datos):** Si el envío que se realiza una vez al día falla debido a problemas de red, los datos se quedan guardados de forma segura en la app del paciente y se reintentará el envío más tarde. No interrumpe la sincronización de alertas críticas del Tier 1.
- **Interfaz de Usuario del Personal (Frontend del Hospital):** Si la aplicación web que usan las enfermeras o médicos se cae, el personal puede recurrir temporalmente a planes de contingencia (como consultar al servicio técnico de guardia para consultas directas a la base de datos o llamadas telefónicas).

Resumen de Priorización para el Plan de Mitigación

Componente	Criticidad	Enfoque de Seguridad Principal
Motor de Alertas / Emergencias	🔥 Crítico (Tier 1)	Alta Disponibilidad y Tolerancia a Fallos
Servicio de Identidad y Acceso (IAM)	🔥 Crítico (Tier 1)	Control de Accesos Estricto (Menor Privilegio)
Sensor e Inteligencia de la App	🔥 Crítico (Tier 1)	Integridad del Dato y Cifrado Extremo a Extremo

Módulo de Auditoría (Logs)	 Alto (Tier 2)	Inmutabilidad (No Modificable/No Borrable)
Base de Datos Clínica	 Alto (Tier 2)	Cifrado en Reposo y Copias de Seguridad
API Gateway (Gestión de Umbrales)	 Alto (Tier 2)	Autenticación Robusta y Filtrado de Peticiones
Servicio de Ingesta Diaria / Frontend	 Operacional (Tier 3)	Resiliencia y Recuperación Post-Caída

Análisis STRIDE y mitigaciones

Categoría STRIDE	#	Componente Afectado	Descripción de la Amenaza	Impacto Potencial	Contramedida de Seguridad
Spoofing (<i>Suplantación</i>)	1	Sensor IoT / App	Dispositivo pirata suplanta al sensor legítimo vía Bluetooth enviando lecturas falsas.	Diagnósticos erróneos o alertas médicas falsas.	Emparejamiento BLE seguro mediante <i>Numeric Comparison</i> y claves criptográficas únicas por sensor.
	2	Backend / IAM	Robo de credenciales médicas mediante <i>phishing</i> para ingresar al sistema central.	Acceso no autorizado a Datos de Salud Protegidos (PHI).	Autenticación Multifactor (MFA) obligatoria y acceso condicional basado en IP/Ubicación.

	3	API Gateway	Envenenamiento de DNS desvía el tráfico de alertas hacia un servidor malicioso externo.	Pérdida de alertas críticas y fuga masiva de datos en tiempo real.	Implementación de DNSSEC y uso de mTLS (TLS mutuo) con validación estricta de certificados.
Tampering (Manipulación)	1	Canal de Ingesta (Red)	Ataque <i>Man-in-the-Middle</i> (MitM) que altera los valores de glucosa en tránsito antes de llegar al hospital.	Alteración del historial clínico permanente del paciente.	Uso obligatorio de TLS 1.3 con <i>Certificate Pinning</i> integrado en el código de la aplicación móvil.
	2	Base de Datos Clínica	Modificación directa en la base de datos de los umbrales de alerta de un paciente.	Desactivación silenciosa de alertas vitales para el paciente.	Firmado criptográfico de registros sensibles (<i>Hash chaining</i>) y cifrado en reposo (TDE).
	3	Firmware del Sensor	Inyección de software malicioso aprovechando una actualización de firmware no verificada.	Secuestro del dispositivo médico o envío de datos estáticos normales.	Firma digital obligatoria de todo firmware mediante criptografía asimétrica verificada por hardware (<i>Secure Boot</i>).

Repudiation (Repudio)	1	API Gateway / Médicos	Un médico cambia un umbral por error, ocurre un incidente y niega haber sido el autor.	Imposibilidad de determinar responsabilidades legales ante negligencias.	Logs firmados digitalmente por el ID del token del médico en cada transacción de cambio.
	2	Terminales de Planta	Personal de enfermería consulta el historial de una celebridad y niega la acción.	Violación de privacidad sin autor detectable; multas por normativas de salud.	Prohibición de cuentas genéricas; cierre de sesión automático por inactividad y autenticación biométrica/tarjeta.
	3	Módulo de Auditoría	Un administrador con privilegios altera las líneas de logs para borrar el rastro de su intrusión.	Pérdida absoluta de la confianza forense del sistema informático.	Almacenamiento de logs en un entorno WORM (Write Once, Read Many) y réplica en tiempo real fuera del entorno local.
Information Disclosure (Fuga de Datos)	1	Servidor de Backups	Robo de copias de seguridad de la base de datos clínica que se guardaban sin protección.	Exposición masiva de historiales médicos en el mercado negro.	Cifrado obligatorio de todos los <i>backups</i> con claves gestionadas en un HSM (Módulo de Seguridad de Hardware).

	2	Almacenamiento Móvil	La app guarda el histórico de glucosa en el almacenamiento local del teléfono en texto plano.	Aplicaciones maliciosas (<i>malware</i>) en el móvil pueden extraer la salud del paciente.	Uso de almacenamiento cifrado nativo de la plataforma (<i>EncryptedSharedPreferences / SQLite cipher</i>).
	3	Red del Hospital (LAN)	Captura de paquetes (<i>sniffing</i>) dentro de la red interna porque el tráfico viaja en HTTP plano.	Exposición de datos médicos a cualquier intruso conectado a la red local del hospital.	Cifrado de extremo a extremo dentro del centro de datos (cero confianza / <i>Zero Trust Network</i>).
Denial of Service (<i>Denegación</i>)	1	API Gateway	Ataque de denegación de servicio distribuido (DDoS) satura la entrada de la API del hospital.	Bloqueo absoluto de la recepción de alertas de emergencia de los pacientes.	Implementación de <i>Rate Limiting</i> estricto por IP/Dispositivo y protección perimetral avanzada (WAF/Cloud Scrubbing).
	2	Sensor IoT (Espectro)	Uso de un inhibidor de frecuencias en el entorno del paciente para bloquear la señal de 2.4 GHz.	Aislamiento del sensor; el paciente queda desprotegido ante variaciones de azúcar.	Alertas locales acústicas/visuales en el móvil si la desconexión con el sensor supera los 20 minutos.

	3	Base de Datos Clínica	Inyección de consultas SQL masivas y complejas que saturan el uso de CPU del servidor.	Caída del sistema informático del hospital; médicos y enfermeras sin acceso a historiales.	Optimización de índices, separación de la base de datos de lectura (réplicas) y tiempos de espera de ejecución (<i>timeouts</i>).
Elevation of Privilege (Elevación)	1	API Gateway / Código	Explotación de vulnerabilidad de asignación masiva de parámetros para cambiar el rol de Enfermería a Médico.	Personal no cualificado modificando umbrales críticos de alerta de salud.	Validación estricta de datos de entrada (<i>White-listing</i>) y verificación de roles del backend en base a claims inmutables.
	2	Aplicación / Autenticación	Manipulación de los parámetros de los tokens de sesión (JWT) cambiando el ID del usuario por el de Admin.	Control total del atacante sobre la configuración global del hospital.	Firma de tokens JWT mediante algoritmos asimétricos robustos (RS256) con verificación estricta de la clave pública.
	3	Servidor de Auditoría	Explotación de un desbordamiento de búfer en el sistema operativo del servidor de logs.	Acceso raíz (<i>Root</i>) del atacante para apagar los sistemas de control y monitorización.	Parcheo y actualización automatizada de sistemas operativos; minimización de superficie de ataque (<i>Hardening</i>).

Para obtener una visión realista del riesgo, un ingeniero de seguridad debe cruzar ambas variables. La **criticidad** (el impacto en el paciente/hospital) y la **probabilidad de explotación** (la facilidad para el atacante) se combinan para calcular el **Nivel de Riesgo Global** utilizando la clásica fórmula de gestión de riesgos:

$$\text{Riesgo} = \text{Criticidad (Impacto)} \times \text{Probabilidad}$$

A continuación, presento la priorización unificada de las 18 amenazas STRIDE identificadas para tu sistema médico, ordenadas de **Mayor Riesgo Global a Menor Riesgo Global**.

Matriz de Priorización de Riesgo STRIDE (Combinada)

- **Riesgo Crítico:** Requiere mitigación inmediata antes de que el sistema reciba cualquier dato real.
- **Riesgo Alto:** Debe mitigarse en las primeras fases del desarrollo.
- **Riesgo Medio/Bajo:** Se gestiona mediante políticas operacionales o parches progresivos.

#	Categoría STRIDE	Componente Afec	Descripción Corta de la Amenaz	Criticidad (Impacto)	Probabilidad de Explotación	Nivel de Riesgo Global
1	Denial of Service	API Gateway	Ataque DDoS que satura el Gatev bloqueando alertas críticas.	🔥 Alta (Tier 1)	📈 Alta	● CRÍTICO
2	Spoofing	Backend / IAM	Phishing de credenciales médicas acceder a historiales.	🔥 Alta (Tier 1)	📈 Alta	● CRÍTICO

3	Elevation of Privilege	API Gateway	Modificación de peticiones para pasar de Enfermería a Médico.	⚠ Alta (Tier 2)	📈 Alta	● CRÍTICO
4	Elevation of Privilege	Autenticación	Manipulación de parámetros de token JWT (identidad Admin).	⚠ Alta (Tier 2)	📈 Alta	● CRÍTICO
5	Spoofing	Sensor IoT / App	Dispositivo BLE pirata inyecta lecturas falsas de azúcar.	🔥 Alta (Tier 1)	📊 Media	● ALTO
6	Information Disclosure	Almacenamiento Móvil	Malware en el móvil extrae datos de salud de la app.	● Operacional	📈 Alta	● ALTO
7	Tampering	Base de Datos	Modificación directa de los umbrales de alerta clínicos.	⚠ Alta (Tier 2)	📊 Media	● ALTO
8	Information Disclosure	Servidor Backups	Robo de copias de seguridad históricas no cifradas.	⚠ Alta (Tier 2)	📊 Media	● ALTO

9	Repudiation	Terminales Planta	Acceso ilegítimo usando sesiones abiertas/compartidas.	⚠ Alta (Tier 2)	📊 Alta	● ALTO
10	Denial of Service	Sensor IoT / BLE	Uso de inhibidor de frecuencias en entorno del paciente.	🔥 Alta (Tier 1)	📉 Baja	● MEDIO
11	Spoofing	API Gateway	Envenenamiento DNS desvía alertas a servidor externo.	🔥 Alta (Tier 1)	📉 Baja	● MEDIO
12	Tampering	Canal de Ingesta	Ataque MitM que altera datos del volcado diario en tránsito.	● Operacional	📊 Media	● MEDIO
13	Denial of Service	Base de Datos	Inyección de consultas SQL pesadas que tumban el sistema.	● Operacional	📊 Media	● MEDIO
14	Repudiation	API Gateway	Un médico cambia un umbral erróneamente y lo niega.	⚠ Alta (Tier 2)	📉 Baja	● MEDIO

15	Information Disclosu	Red Hospitalaria	Sniffing de datos de salud en tránsito local por HTTP plano.	⚠ Alta (Tier 2)	📉 Baja	● MEDIO
16	Tampering	Firmware Sensor	Modificación del código interno de del glucómetro.	🔥 Alta (Tier 1)	📉 Baja	● MEDIO
17	Repudiation	Módulo Auditoría	Un administrador borra líneas de log para ocultar su rastro.	⚠ Alta (Tier 2)	📉 Baja	● MEDIO
18	Elevation of Privilege	Servidor Auditoría	Explotación de <i>Buffer Overflow</i> para ganar acceso Root.	⚠ Alta (Tier 2)	📉 Baja	● BAJO

Módulo científico

Abrir una base de datos médica con fines de investigación científica (Big Data / Machine Learning) introduce una superficie de ataque completamente nueva. El mayor reto aquí es que **la anonimización total en salud es extremadamente difícil** debido a los ataques de correlación de datos.

Identificación de Amenazas STRIDE (Módulo de Investigación)

- **Spoofing (Suplantación):** Un atacante se hace pasar por un investigador universitario legítimo (robando sus credenciales o falseando su afiliación) para obtener acceso al portal de descarga de datos anonimizados.
- **Tampering (Manipulación):** Un actor malintencionado inyecta datos falsos o altera los registros del dataset de investigación para sesgar los resultados de un estudio científico (sabotaje farmacéutico o académico).
- **Repudiation (Repudio):** Un investigador extrae el dataset completo del hospital hacia un servidor externo no autorizado y el sistema no es capaz de demostrar qué científico realizó la descarga debido a la falta de firmas digitales en las peticiones de exportación.
- **Information Disclosure (Fuga de Información - Ataque de Reidentificación):** El atacante cruza el dataset "anonimizado" (que incluye fechas de nacimiento, códigos postales y niveles de glucosa) con una base de datos pública (como el censo electoral o noticias locales). Al hacerlo, logran **identificar** a un paciente específico (ej. "Solo hay una persona de 65 años en este código postal que tuvo una crisis de glucosa el martes").
- **Denial of Service (Denegación de Servicio):** Un usuario lanza consultas analíticas masivas de inteligencia artificial (agregaciones pesadas, correlaciones complejas) directamente contra la base de datos de investigación, agotando los recursos del servidor y bloqueando el trabajo de los científicos.
- **Elevation of Privilege (Elevación de Privilegios):** Un usuario con rol de **Investigador Externo** (que solo debería ver datos agregados y anonimizados) explota una vulnerabilidad en la API de consultas para acceder a la base de datos de producción con privilegios de **Médico**, visualizando nombres, apellidos y DNI de los pacientes reales.

Matriz de Riesgo: Priorización de Amenazas Científicas

Para calcular el **Nivel de Riesgo Global**, recordamos la fórmula:

Riesgo = Criticidad (Impacto) x Probabilidad de explotación

En este escenario de investigación, **el impacto ya no es la muerte inmediata del paciente** (ya que no tocamos el Motor de Alertas en tiempo real), sino el **impacto legal catastrófico (RGPD)** y la pérdida de reputación si se viola la privacidad de miles de personas.

#	Categoría STRIDE	Componente/Proceso Afectado	Descripción de la Amenaza	Criticidad (Impacto)	Probabilidad de Explotación	Nivel de Riesgo Global
1	Information Disclosure	Dataset Anonimizado	Ataque de Reidentificación: Cruce de datos anonimizados con fuentes públicas para identificar pacientes reales.	🔥 Alta (Multas multimillonarias y pérdida de reputación)	📊 Alta (Es el objetivo principal de los atacantes de datos masivos)	● CRÍTICO
2	Spoofing	Portal de Investigadores	Suplantación de la identidad de un científico para acceder al portal de datos.	⚠️ Media-Alta (Acceso a PHI masivo)	📊 Alta (Phishing o credenciales débiles)	● CRÍTICO
3	Elevation of Privilege	API de Consultas	Investigador explota vulnerabilidad para saltar a la BD de producción con nombres reales.	🔥 Alta (Acceso a datos de pacientes reales)	📊 Media (Requiere descubrir un <i>exploit</i> en la API)	● ALTO
4	Repudiation	Módulo de Exportación	Fuga de datasets por parte de un investigador sin que el hospital pueda probar quién fue.	⚠️ Media (Pérdida de trazabilidad legal)	📊 Alta (Si no se implementa marca de agua o firma digital)	● ALTO

5	Denial of Service	Servidor Analítico	Consultas de Big Data masivas que saturan la base de datos de investigación.	 Baja-Media (No afecta a las alertas médicas, solo a la ciencia)	 Media (Puede ocurrir incluso por error de los propios científicos)	 MEDIO
6	Tampering	Pipeline de Datos	Manipulación de los datos del estudio para sabotear o alterar conclusiones científicas.	 Media (Impacto reputacional en la investigación)	 Baja (Requiere motivación muy específica de sabotaje)	 MEDIO

Conclusiones del Análisis de Riesgo

1. **El peligro de las "Puertas Traseras" lógicas (Riesgo Crítico):** Las amenazas de **Elevación de Privilegios (#3 y #4)** se posicionan en lo más alto. Aunque conceptualmente no detienen el envío de una alerta como un DDoS, su probabilidad es muy alta debido a la automatización de herramientas de hacking de APIs. Si un atacante altera los JWT, toma el control total del backend médico.
2. **El factor humano y perimetral (Riesgo Crítico/Alto):** El **Phishing (#2)** y el **DDoS (#1)** son certezas en el entorno actual de ciberseguridad hospitalaria. Al estar expuestos directamente a la acción humana y a Internet, la probabilidad satura el riesgo.
3. **Los mitos de las amenazas de hardware (Riesgo Medio):** Modificar el **Firmware de un sensor (#16)** o usar un **Inhibidor de frecuencias (#10)** tiene una de las criticidades más altas del diseño (pueden causar la muerte del paciente por desinformación). Sin embargo, al requerir que el atacante persiga físicamente a un paciente en su día a día o tenga un laboratorio de ingeniería inversa microelectrónica, su riesgo real decae a "Medio" debido a su bajísima probabilidad de explotación masiva. Un hacker siempre preferirá atacar el API Gateway desde su casa que perseguir a un paciente por la calle.
4. Debemos implementar tres defensas arquitectónicas antes de escribir la primera línea de código del módulo científico:
 1. **Privacidad Diferencial (Differential Privacy):** No basta con "borrar el nombre". Se debe inyectar ruido matemático controlado al dataset analítico. De este modo, los científicos pueden obtener patrones estadísticos globales precisos (ej. "El 20% de los pacientes de la región sufre hiperglucemia a las 4 PM"), pero es matemáticamente imposible revertir el dato para saber qué paciente específico sufrió la crisis.
 2. **Arquitectura Aislada (Data Warehouse Independiente):** Jamás se permite a los investigadores lanzar consultas contra la base de datos donde operan los médicos. Se debe crear un proceso ETL (*Extract, Transform, Load*) que extraiga,



limpie, anonimice y mude los datos una vez al mes a un entorno en la nube completamente aislado.

3. **Marcado de Agua Criptográfico (Data Watermarking):** Al exportar un dataset para un investigador, el archivo debe llevar una marca de agua invisible incrustada criptográficamente con el ID del investigador. Si el dataset se filtra en Internet, el hospital sabrá exactamente qué científico violó el acuerdo de confidencialidad.